

EENDRAG HUB

Full Codebase Audit Report

July 13, 2026 • React + Supabase Alumni Platform

Executive Summary

A thorough review of all 50+ source files across the Eendrag Hub codebase identified ~80 issues spanning security vulnerabilities, data integrity bugs, performance bottlenecks, UX gaps, and missing features. The findings below are grouped by severity and area. The 9 critical issues should be addressed before any new feature work.

Severity	Count	Top Area	Fix Effort
Critical	9	Data integrity, XSS	1-2 days
High	16	Auth, perf, state	3-5 days
Medium	~30	UX, validation	1-2 weeks
Low	~25	Polish, a11y	Ongoing

Critical Issues (9) — Will Break or Already Broken

[Critical] 1. Event date schema mismatch — new events invisible in listings

EventFormEnhanced writes to event_start_time/event_end_time, but Events.jsx queries and sorts on event_date. Newly created/edited events have null event_date, so they don't appear in the listing or appear in the wrong order. Home.jsx dashboard also reads event_date.

- Files: Events.jsx line 28, EventFormEnhanced.jsx line 143, Home.jsx line 229
- Fix: Write event_date in EventFormEnhanced or add a DB trigger to sync the columns

[Critical] 2. Events SELECT missing fields — edit mode loses data

EVENTS_SELECT doesn't fetch event_start_time, event_end_time, event_url, image_url, or max_registrations. When editing, the form initializes with undefined values. Date picker starts empty, image/URL/registration limit are lost.

- Fix: Add missing columns to EVENTS_SELECT

[Critical] 3. BusinessDescriptionEditor never renders existing content

The contentEditable div never has innerHTML set from the value prop. When editing an existing business, the description editor appears empty. Users can accidentally save an empty description, overwriting the real one.

- File: BusinessDescriptionEditor.jsx line 84-95
- Fix: Set innerHTML from value on mount/when value changes

[Critical] 4. Jobs filter count always shows 3 active filters

activeFilterCount checks Object.values(filters).filter(v => v !== '' && v !== false).length. Empty arrays [] pass both checks, so the 3 array-type filters (companies, locations, industries) always count. The filter badge always shows '3', and 'Load more' pagination breaks since it's hidden when activeFilterCount !== 0.

- File: Jobs.jsx line 290
- Fix: Add Array.isArray check: v !== '' && v !== false && !(Array.isArray(v) && v.length === 0)

[Critical] 5. XSS via plainText() helper — 9+ locations

div.innerHTML = untrustedHtml is used to extract plain text in Admin.jsx, Feed.jsx, Jobs.jsx, BusinessDirectory.jsx, GlobalSearch.jsx, GroupDetail.jsx, Home.jsx, Merchandise.jsx. Certain payloads (e.g.,) fire event handlers during innerHTML assignment.

- Fix: Replace with new DOMParser().parseFromString(html, 'text/html').body.textContent

[Critical] 6. FloatingMessages realtime subscription fires on ALL messages platform-wide

The subscription has no filter clause. Every message inserted by any user triggers refreshUnread(), which fires an RPC call. With 100 concurrent users, every browser fires 100 RPCs/minute. This is a scaling time bomb.

- File: FloatingMessages.jsx line 34
- Fix: Add a filter scoped to the user's conversation IDs, or debounce heavily

[Critical] 7. Messages thread list fetches ALL messages without limit

Messages.jsx fetches all messages across all conversations with no .limit(). A user with 20 conversations of 500 messages each loads 10,000 rows just to extract the latest per thread.

- File: Messages.jsx line 65-67
- Fix: Use an RPC that returns only the last message per conversation

[Critical] 8. No React error boundary — any render error white-screens the entire app

main.jsx wraps <App /> in BrowserRouter and ToastProvider but no ErrorBoundary. Any unhandled render error in any component crashes the entire app with no recovery path.

- Fix: Add an ErrorBoundary component around <App />

[Critical] 9. Two conflicting delete-account implementations

Profile.jsx calls `supabase.functions.invoke('delete-account')` (Edge Function). Settings.jsx calls `supabase.rpc('delete_own_account')` (DB RPC). If only one is deployed, the other silently fails. Settings.jsx also doesn't reload after sign-out, leaving the app in a broken state.

- Fix: Consolidate to a single implementation and ensure both UI paths use it

High Issues (16) — Likely to Cause Real Problems

[High] 1. Failed geocode lookups permanently cached as null

If Mapbox is temporarily down, the null result is saved to localStorage and served forever. That city's pin never appears until someone clears localStorage.

- Fix: Only cache non-null results, or add TTL for null entries

[High] 2. confirmSaveAndLeave can leave leaveBusy stuck true

If profileSaveRef.current() throws, setLeaveBusy(false) is never reached. The 'Save & leave' button stays permanently disabled.

- Fix: Wrap in try/finally

[High] 3. MutationObserver on .content fires on every DOM change

repositionSidebar triggers layout reflow on every mutation. On dynamic pages (Feed with infinite scroll), this fires hundreds of times per second.

- Fix: Throttle with requestAnimationFrame

[High] 4. No handling of expired/revoked refresh tokens

If a refresh token fails, the app continues rendering the authenticated layout while every Supabase call silently fails. User sees a logged-in app where nothing works.

[High] 5. PersonProfile treats network errors as 'not found'

The Supabase error field is never checked. Network failures show 'Couldn't find that profile' instead of a retry option.

[High] 6. Password change doesn't require current password

Anyone with physical access to an unlocked device can change the password without knowing the current one. Settings.jsx line 97-108.

[High] 7. Notification preferences upsert creates incomplete rows

Upserting a single preference column creates a row with only that column set. Other preferences fall to DB defaults which may differ from UI defaults, flipping toggles unexpectedly.

[High] 8. Profile.jsx doesn't trim most fields

Only linkedin_url and phone are trimmed. Names, degrees, occupations etc. save with leading/trailing whitespace. Onboarding does trim full_name, creating inconsistency.

[High] 9. Feed realtime INSERT resets everyone to page 1

When any user posts, all viewers have their feed replaced with page 1. Users reading older posts lose their scroll position and loaded history.

[High] 10. GroupDetail image positioning editor saves data that is never applied

Users can pan/zoom a cover image, but submit() uploads the raw file — positioning data is discarded. The feature appears to work but silently does nothing.

[High] 11. DirectoryFilters loads ALL profiles client-side

The entire profiles table is loaded into memory on every mount. All filtering happens client-side. Does not scale.

[High] 12. Photos 'YOUR GROUPS' filter button does nothing

filterMode state toggles on click but neither filteredAlbums nor filteredPhotos uses it.

[High] 13. MerchDetail wishlist is purely ephemeral

Heart button toggles local state only, never persists. Every refresh resets. The button implies functionality that doesn't exist.

[High] 14. MerchDetail quantity ignored in order message

User selects quantity 3 but the order message only mentions size and color.

[High] 15. richTextExtended renders user URLs directly as href — javascript: XSS risk

[click me](javascript:alert(1)) markdown renders as a clickable XSS link. Needs explicit protocol whitelisting.

[High] 16. Missing DB indexes on critical foreign key columns

posts.author_id, messages.conversation_id, messages.sender_id, conversation_participants.user_id all lack indexes. Feed and message queries will do full table scans as data grows.

Medium Issues (~30) — UX Problems & Validation Gaps

- [Medium] 1. No 404 page — unknown routes silently redirect to /home
- [Medium] 2. No <form> elements anywhere — Enter key doesn't submit login/signup
- [Medium] 3. No client-side validation on Auth (empty email/password hit server)
- [Medium] 4. No graduation year range validation (accepts 0, -5, 99999)
- [Medium] 5. No focus trap in ProfileModal (Tab escapes to background)
- [Medium] 6. Settings saves swallow errors silently (language, notifications)
- [Medium] 7. Profile URL fields lack protocol validation (potential javascript: URIs)
- [Medium] 8. Onboarding loses all progress on tab close (no intermediate saves)
- [Medium] 9. Profile.jsx: full_name not required — users save empty names
- [Medium] 10. URL.createObjectURL never revoked in Feed/GroupDetail composers (memory leak)
- [Medium] 11. GlobalSearch ilike pattern doesn't escape _ wildcard
- [Medium] 12. Comments have no realtime — users don't see each other's new comments
- [Medium] 13. Messages auto-scroll interrupts reading older messages
- [Medium] 14. Groups join button can double-fire, causes state confusion
- [Medium] 15. GroupDetail leave() ignores errors — UI shows 'left' but server disagrees
- [Medium] 16. Feed search only covers loaded posts, not the full database
- [Medium] 17. Leaflet MapContainer center not reactive — map doesn't re-center
- [Medium] 18. Mentoring N+1 query — individual RPC per program for match counts
- [Medium] 19. Donate/Merch pages use .example.com email (doesn't receive mail)
- [Medium] 20. Admin delete operations don't check errors — optimistic removal
- [Medium] 21. RichTextEditor has no character counter matching DB 4000-char limit
- [Medium] 22. DateTimePicker: changing time without date silently picks 'today'
- [Medium] 23. ReportButton allows duplicate reports on same entity
- [Medium] 24. z-index collisions — dropdowns at 10000 can render above modal backdrop at 2000
- [Medium] 25. Notifications navigate to tab generically, not to the specific entity
- [Medium] 26. No message pagination — all messages loaded at once per conversation
- [Medium] 27. vercel.json missing security headers (CSP, HSTS, X-Frame-Options)

[Medium] 28. Home.jsx fires 10+ parallel queries plus N sequential group queries on load

[Medium] 29. Deleted storage files (photos, logos) never cleaned up — orphans accumulate

[Medium] 30. No pagination on Photos or BusinessDirectory — loads all records

Low Issues (~25) — Polish, Accessibility & Nice-to-haves

- [Low] 1. 85+ vite .timestamp- junk files in project root
- [Low] 2. dist.old, dist.old.2, dist.old.3, dist.old.4 directories still in repo
- [Low] 3. testfile123, 'earch more broadly' junk files in root
- [Low] 4. No code-splitting — all 20+ page components eagerly imported
- [Low] 5. No test framework or linter configured
- [Low] 6. Sign-out doesn't clear DM drafts/targets — next user on same tab could see them
- [Low] 7. PhoneInput dropdown has no keyboard navigation (200+ countries via Tab only)
- [Low] 8. DateTimePicker minutes limited to 0/15/30/45
- [Low] 9. Multiple modals lack role='dialog' and focus trapping
- [Low] 10. EmptyState/LoadingState missing ARIA live-region attributes
- [Low] 11. ClearableInput doesn't restore focus after clearing
- [Low] 12. Dead code: COLLABORATION_TYPES constant, Imagemcon in Home, JobModal.jsx
- [Low] 13. Dead CSS: .tabs/.tab classes from old nav
- [Low] 14. Icebreaker only matches on industry — could leverage city, grad_year, section
- [Low] 15. Duplicate formatExperienceRange in ProfileModal diverges from shared utility
- [Low] 16. Password not cleared from input after successful signup
- [Low] 17. Email change feedback ambiguous — shows new email but reverts on refresh
- [Low] 18. Inconsistent delete-account UX — Profile uses window.confirm, Settings uses ConfirmDialog
- [Low] 19. Thread preview text not truncated — long messages overflow
- [Low] 20. Orphan conversations accumulate (created but never messaged)

Missing Features — Expected on an Alumni Platform

[Medium] Messaging: No typing indicators, read receipts, message deletion/editing, or reactions

[Medium] Groups: No search, no post pagination, no group post permissions

[Medium] Feed: No virtualization for large lists, no 'see all results' in global search

[Medium] Events: No calendar view integration, no iCal export

[Low] Mentoring: No edit/delete for program owners

[Low] Donate: No actual payment integration (static placeholder)

[Low] Notifications: No preference controls (can't mute types)

[Low] Global search: Post title not searched, only content

Recommended Fix Priority

Week 1 — Critical fixes (items that are actively broken):

- Fix event date schema mismatch and EVENTS_SELECT (#1, #2)
- Fix BusinessDescriptionEditor initial content (#3)
- Fix Jobs filter count (#4)
- Replace plainText() with DOMParser (#5)
- Scope FloatingMessages realtime subscription (#6)
- Add limit to Messages thread query (#7)
- Add React ErrorBoundary (#8)
- Consolidate delete-account implementations (#9)

Week 2 — High-priority fixes (will cause problems at scale):

- Fix geocode null caching, confirmSaveAndLeave try/finally
- Throttle MutationObserver, handle expired tokens
- Add DB indexes on foreign key columns
- Fix profile field trimming, notification preferences upsert
- Remove dead image positioning editor or implement it properly

Ongoing — Medium/Low improvements:

- Add <form> elements for Enter-to-submit
- Add validation (grad year, auth fields, URL protocols)
- Add pagination to Photos, BusinessDirectory, Messages
- Add security headers to vercel.json
- Clean up junk files, add code-splitting, set up testing